// MLSECOPSHUB · READINESS CHECKLIST

ISO/IEC 42001 security checklist

Framework: ISO/IEC 42001:2023, Artificial intelligence management system (AIMS)
Official source: https://www.iso.org/standard/42001
Online version and control mapping: https://mlsecopshub.com/readiness/iso-42001
Last updated 2026-09-08. 32 items. Obligations are paraphrased; engineering guidance, not legal advice.

Clauses 4 and 5: scope and leadership

- [ ] Define the AIMS scope and state whether the organization is a provider, deployer or developer per system.
- [ ] Publish an AI policy signed by top management that names security risk classes.
- [ ] Assign an owner for the AIMS and an owner for each production AI system.
- [ ] Record interested parties and their requirements, including regulators and customers.
- [ ] Schedule management reviews at least annually.

Clause 6: planning and risk

- [ ] Complete an AI risk assessment per system using a documented method.
- [ ] Complete an AI system impact assessment covering affected individuals and groups.
- [ ] Write a risk treatment plan with owners and dates.
- [ ] Produce a Statement of Applicability that justifies every excluded Annex A control.
- [ ] Set measurable AI objectives and record how they are tracked.

Clauses 7 and 8: support and operation

- [ ] Train engineers who handle model artifacts on safe loading and provenance verification.
- [ ] Maintain document control for all AIMS records.
- [ ] Document operational planning and control for every AI system in scope.
- [ ] Define the AI incident reporting process and its recipients.

Annex A.6 and A.7: lifecycle and data

- [ ] Scan every model artifact for unsafe serialization before it enters the registry.
- [ ] Reject pickle-based artifacts unless a documented exception exists.
- [ ] Verify signatures and pinned digests on every model pull.
- [ ] Run prompt-injection and tool-authorization tests in CI before deployment.
- [ ] Generate an AI bill of materials in CI covering models, datasets and external tools.
- [ ] Record dataset provenance, license and preparation steps.
- [ ] Log prompts and tool calls with retention that supports investigation.
- [ ] Treat retrieval corpora and agent tool outputs as untrusted input.

Annex A.9 and A.10: use and third parties

- [ ] Write an intended-use statement per system.
- [ ] Scope agent tools to least privilege and require approval for irreversible actions.
- [ ] Apply an intake procedure to every third-party model, dataset and MCP server.
- [ ] Assess model providers and MCP server publishers as suppliers.
- [ ] Allocate security responsibilities with customers in contracts.

Clauses 9 and 10: evaluation and improvement

- [ ] Report security metrics per AI system to management review.
- [ ] Run an internal audit of the AIMS before the certification audit.
- [ ] Log nonconformities and corrective actions.
- [ ]

Update the threat model and test suites after every incident.

- [ ] Rehearse model rollback and tool revocation at least twice a year.

```
Have this run against your pipeline: https://mlsecopshub.com/services
Book a 30-minute assessment call: https://mlsecopshub.com/contact
```